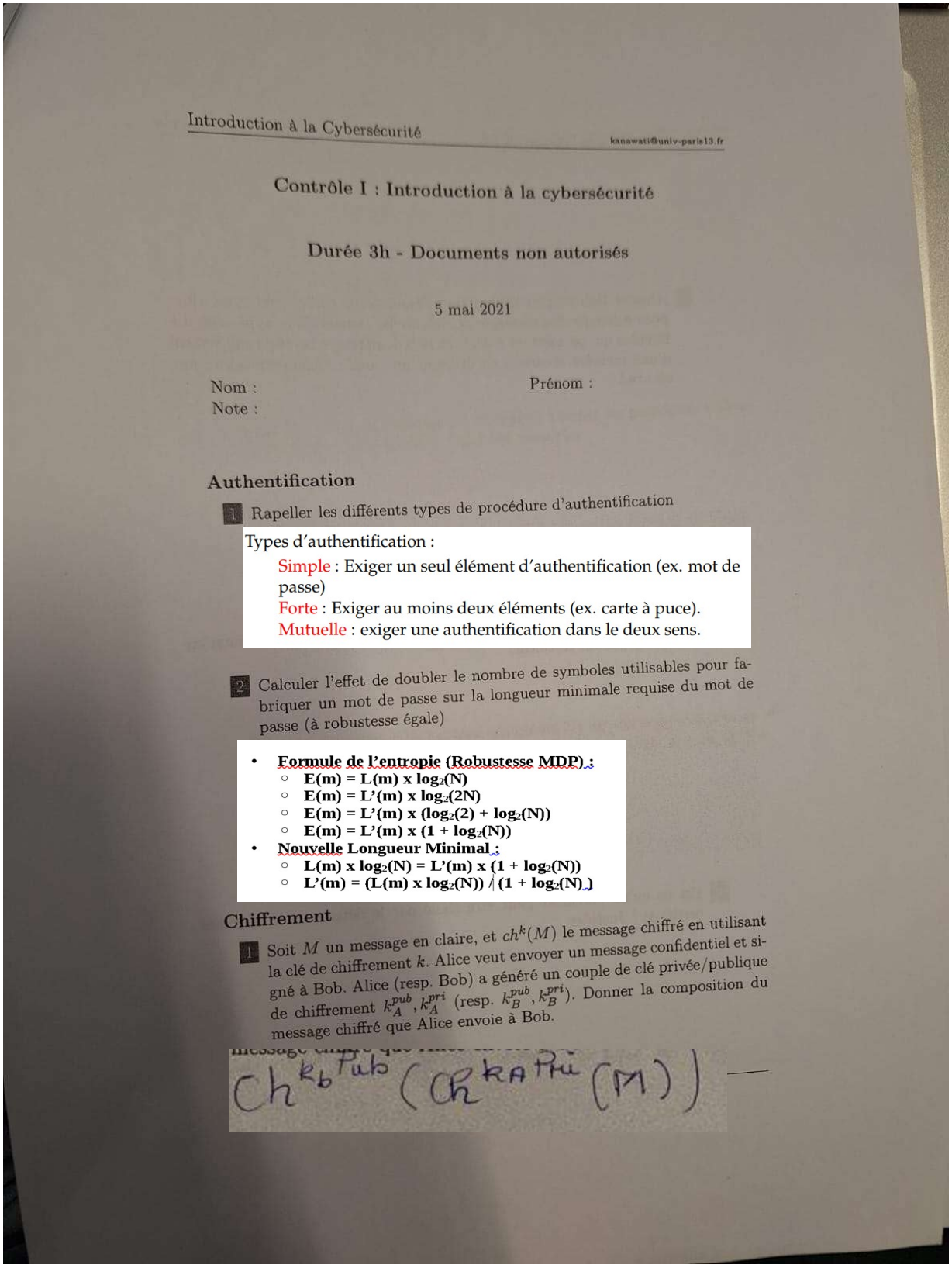
CYBERSÉCURITÉ 2021



Contrôle I : Introduction à la cybersécurité

Durée 3h - Documents non autorisés

5 mai 2021

Nom : Prénom :
Note :

Authentification

1 Rapeller les différents types de procédure d'authentification

Types d'authentification :
- Simple : Exiger un seul élément d'authentification (ex. mot de passe)
- Forte : Exiger au moins deux éléments (ex. carte à puce).
- Mutuelle : exiger une authentification dans le deux sens.

2 Calculer l'effet de doubler le nombre de symboles utilisables pour fabriquer un mot de passe sur la longueur minimale requise du mot de passe (à robustesse égale)

- **Formule de l'entropie (Robustesse MDP) :**
  - **E(m) = L(m) x $\log_2$(N)**
  - **E(m) = L'(m) x $\log_2$(2N)**
  - **E(m) = L'(m) x ($\log_2$(2) + $\log_2$(N))**
  - **E(m) = L'(m) x (1 + $\log_2$(N))**
- **Nouvelle Longueur Minimal :**
  - **L(m) x $\log_2$(N) = L'(m) x (1 + $\log_2$(N))**
  - **L'(m) = (L(m) x $\log_2$(N)) / (1 + $\log_2$(N))**

Chiffrement

1 Soit M un message en claire, et $ch^k(M)$ le message chiffré en utilisant la clé de chiffrement k. Alice veut envoyer un message confidentiel et signé à Bob. Alice (resp. Bob) a généré un couple de clé privée/publique de chiffrement k_A^{pub}, k_A^{pri} (resp. k_B^{pub}, k_B^{pri}). Donner la composition du message chiffré que Alice envoie à Bob.

$Ch^{k_B^{Pub}}(Ch^{k_A^{Pri}}(M))$

2 Alice et Bob veulent utiliser un mécanisme de chiffrement symétrique pour échanger des messages confidentiels. Donner deux approches différentes qui permettent à Alice et Bob de partager la clé de chiffrement d'une manière sécurisée en utilisant un canal de communication non sécurisé.

CHIFFREMENT SYMÉTRIQUE : ÉCHANGE DE LA CLÉ

- Approche 1 : échanger la clé en utilisant un algorithme de chiffrement asymétrique
- Approche 2 : Génération de clé secrète : Mécanisme Diffie-Hellman :

  Alice et Bon choisissent un nombre premier p et un générateur g modulo p
  Alice choisit un nombre secret a : $1 \leq a \leq p-1$
  Bob choisit un nombre secret b : $1 \leq b \leq p-1$
  Alice envoie à Bob $A = g^a[modp]$
  Bob envoie à Bob $B = g^b[modp]$
  Clé secrète : $(B[modp])^a = B^a[modp] = g^{ba}[modp] = (A[modp])^b$

3 Qu'est ce un certificat numérique ? donner les principales information fournies par un certificat.

- Un certificat = un document numérique **signé** contenant une **clé publique** et l'identification du porteur de cette clé
- **Signature** par :
  - autorité de certification
  - membre d'un réseau de confiance

Données	`Version:`	Version du type de certificat X.509
	`Serial number:`	Numéro de série au sein de l'AC
	`Signature algorithm:`	Algorithme de signature utilisé
	`Issuer:`	Identité de l'AC (*Distinguished Name*) qui a émis ce certificat

	`Validity`
	`Not before: xx`
	`Not after : xx`
		Période de validité du certificat : dates de début et de fin

	`Subject:`	Identité du propriétaire (*Distinguished Name*) du certificat
	`Subject Public Key Info:` `Public Key Algorithm:`	Informations sur la clé publique et les paramètres de celle-ci

	`X509v3 extensions:`
	`Extension name:`
	`Extension value`
	`...`
		Extensions optionnelles propres à la version 3

Signature	`Signature algorithm:`	Algorithme utilisé pour la signature
	`Signature`	Signature du certificat

4 Est ce qu'un certificat peut être signé par le détenteur de ce même certificat ? Justifier

- Une AC possède son propre couple (clé privée, clé publique) associé à un certificat qui peut être, soit **auto-signé** ou signé par une autre AC.

5 Qu'est ce qu'une fonction de Hachage ? Donner les principale utilisations d'une telle fonction. Citer des exemples

Une fonction de hachage est une fonction à **sens unique** qui prend en entrée des données de longueur quelconque et rend une valeur de taille fixe

- Stockage des mots de passe.
- Signature
- Garantir l'intégrité des données transmises

EXEMPLE : L'ALGORITHME MD5

- MD5 (Message Digest) 5 étapes.
- Calcule une empreinte de 128 bits
- Utilisation de 4 registres de 32 bits : A, B, C, D

SHA : Secure Hash Algorithm
SHA-1 : empreinte de 160 bits. Encore très utilisé
SHA-2 : empreinte de 224, 256, 384 ou 512 bits
SHA-3 : empreinte de 224, 256, 384, 512 ou arbitraire bits.

6 Soit une fonction de hachage qui génère d'empreintes de longueur de n bits. Calculer le nombre d'essais qu'il faut pour avoir plus de 50% de chance de générer une collision

7 Quel est le rôle d'une infra structure de gestion de clés (PKI : Public Key Infrastructure) ? Donner les différents services d'une telle infra structure

Une PKI joue un rôle crucial dans la sécurisation des communications numériques en fournissant les mécanismes nécessaires pour l'authentification, la confidentialité et l'intégrité des données

- IGC : Infrastructure de Gestion de Clés
- PKI : Public Key Infrastructure
- Services :
  - Enregistrement de utilisateurs
  - Génération et renouvellement des certificats
  - Révocation des certificats
  - Publication des certificats et des révocations
  - Service de séquestre et de recouvrement des clés privées ! (rare à mettre en place)

...ion à la Cybersécurité

IDS

kanawati@univ-paris13.fr

1 Comparer en termes d'avantages et des inconvénients H-IDS

NIDS: Avantages & Inconvénients

Avantages

- Supervision de tout un réseau
  pas besoin d'installer des IDS orientés hôtes sur chaque machine
- Déploiement sans perturbation de l'architecture réseau
- Indépendant des OS employés sur les différentes machines
- Détection en temps réel

Inconvénients

- Faible performances en cas de traffic intense
- Non opérationnel avec les flux chiffrés
- Difficulté à traiter les fragments IP.

HIDS: IDS orienté Hôte

Avantages : Compatible flux crypté, pas d'ajout d'équipements, vérification de l'attaque

inconvénients : OS dépendent, utilisation des ressources des machines, pas de détection en temps réel (analyse des log).

2 Un IDS examine une séquence de 50 paquets IP. Il déclare 13 paquets comme étant liés à des attaques. En réalité, 23 paquets sont liés à des attaques dont seulement 7 font parti des 13 détectés par l'IDS. Donner les performances de ce IDS en termes de `précision`, de `rappel`, de sensibilité et de spécificité .

sensibilité et de spécificité .

\ réalité / système \	Attaque	pas Attaque
Attaque	VP = 7	FP = 6
pas Attaque	FN = 16	VN = 21

Précision : P = VP/(VP+FP) = 7/(7+6) = 53.85 %

Rappel = Sensibilité : R = VP/(VP+FN) = 7/(7+16) = 30.43 %

Spécificité = VN/(VN+FP) = 21/(21+6) = 77.78 %

F1 = 2PR/(P+R) = 0.39

Architecture de pare-feu

Nous considérons le cas d'une entreprise connectée à l'Internet. L'entreprise est attribué l'adresse publique : 194.160.12.1/24. Le réseau de l'entreprise est composé de deux sous-réseaux : un réseau de production et un réseau de serveurs publiques (http, DNS, etc.)

Le cahier des charges pour la protection du réseau de l'entreprise est le suivant :

1. Aucune connexion n'est autorisée vers le réseau de production venant d'un autre réseau.
2. Aucune connexion ne peut être initiée vers n'importe quelle machine à partir du réseau de serveurs.
3. Les machines du réseau de production sont autorisées à envoyer des paquets `ICMP Echo-Request` à n'importe quelle machine. Elle sont autorisées aussi à recevoir des paquets `ICMP Echo-Reply`. Par contre elles ne sont pas autorisées à recevoir de paquets `ICMP Echo-Request`
4. La navigation sur le web est autorisée à partir du réseau de production.
5. Les machines de production doivent être protégées contre les attaques de type *balayage*.
6. Les serveurs doivent être protégés contre les attaques classiques de saturation.

Nous proposons une **architecture en T** : Les serveurs sont placés dans une zone `DMZ`. Un seul pare-feu protège les deux réseaux de l'entreprise : la `DMZ` et le réseau de production. La figure 1 illustre cette architecture.

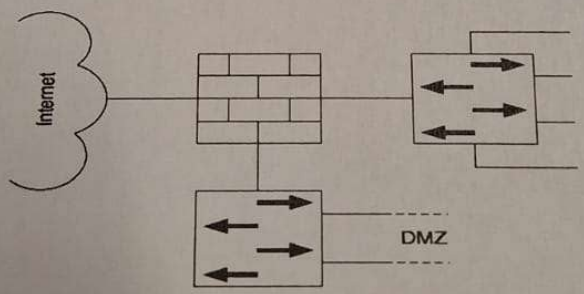
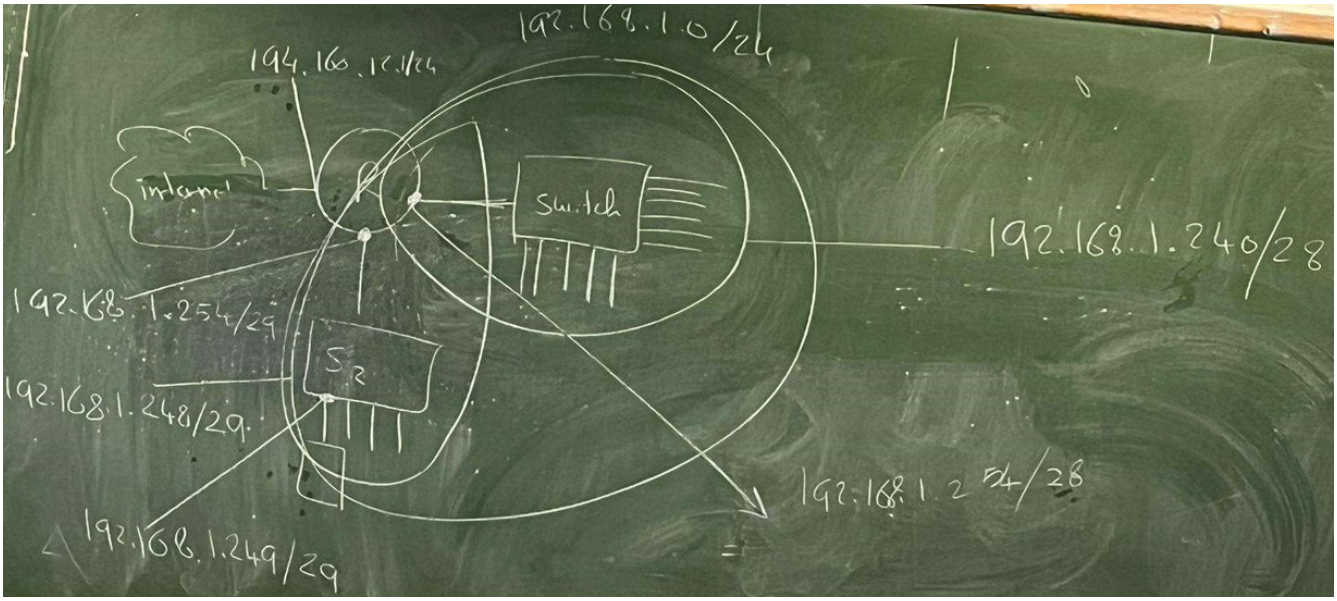


FIGURE 1 – Architecture en T

1. On suppose que le réseau de production est composé de 10 machines, et que le réseau de serveurs (la DMZ) est composé de 4 machines.



2 Donner, en syntaxe iptables, la configuration du pare-feu

IPTABLES -P FORWARD DROP
IPTABLES -P INPUT DROP
IPTABLES -P OUTPUT DROP

1) IPTABLES -t NAT -A POSTROUTING -o eth0 -J MASQUERADE

2) IPTABLES -A FORWARD -s 192.168.1.240/28 -p ICMP --icmp-type echo-request -J ACCEPT

3) IPTABLES -A FORWARD -d 192.168.1.240/28 -p ICMP --icmp-type echo-reply -m state --state ESTABLISHED,RELATED -J ACCEPT

4) IPTABLES -A FORWARD -s 192.168.1.0/24 -p tcp --flags RST, none -J DROP

5) IPTABLES -A FORWARD -s 192.168.1.240/28 -p tcp -multiport -dport 80,443 -m state --state NEW,ESTABLISHED -J ACCEPT

Evaluation de la performaznce d'un IDS

1. La *précision* et le *rappel* sont deux critères pour évaluer les performances d'un IDS. Rappeler les définitions de ces deux critères. Quel critère est à privilégier pour le choix d'une solutionI IDS ?

Définitions

1. **Précision (Precision) :**
   - **Définition :** La précision est la proportion des alertes générées par l'IDS qui sont effectivement des intrusions réelles. Elle mesure la qualité des alertes de l'IDS.
   - **Formule :**

$$\text{Précision} = \frac{\text{Vrai Positifs (VP)}}{\text{Vrai Positifs (VP)} + \text{Faux Positifs (FP)}}$$

   - **Interprétation :** Une haute précision signifie que la majorité des alertes générées par l'IDS sont pertinentes et représentent de véritables menaces.

2. **Rappel (Recall) :**
   - **Définition :** Le rappel est la proportion des intrusions réelles qui sont correctement détectées par l'IDS. Il mesure la capacité de l'IDS à détecter toutes les intrusions.
   - **Formule :**

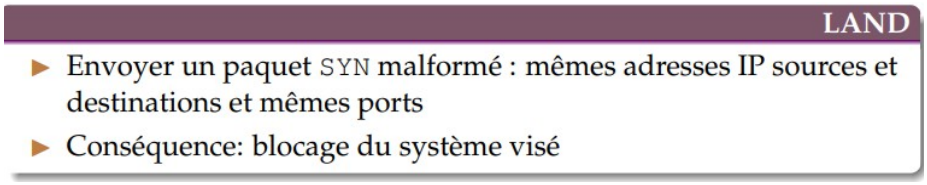
$$\text{Rappel} = \frac{\text{Vrai Positifs (VP)}}{\text{Vrai Positifs (VP)} + \text{Faux Négatifs (FN)}}$$

   - **Interprétation :** Un haut rappel signifie que l'IDS détecte la majorité des intrusions, minimisant ainsi les faux négatifs.

Le choix entre précision et rappel pour une solution IDS doit être basé sur une évaluation approfondie des besoins spécifiques de l'organisation, des ressources disponibles, et des risques potentiels. En général :

- Privilégiez **la précision** si les ressources sont limitées et si les faux positifs peuvent causer des interruptions majeures.
- Privilégiez **le rappel** si la sécurité complète et la détection de toutes les menaces sont critiques pour l'organisation.

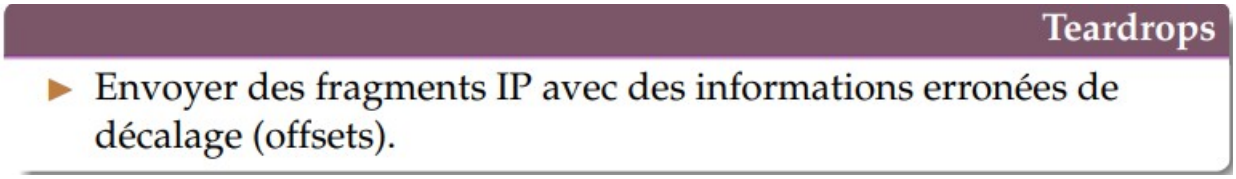
Q1. Décrire le schéma des attaques Land et Teardrops
R1.
- Définition attaque LAND :



- Schéma attaque LAND :

Paquet Spoofé ----> **Port Identique** ----> **Crash/blocage du système cible**

- Définition attaque Teardrops :



- Schéma attaque Teardrops :

Paquet Spoofé ----> **Port Identique** ----> **Crash/blocage du système cible**

Q2. Laquelle des attaques par saturation suivantes est plus efficace: rafales de segments TCP/SYN ou rafales de ICMP echo-request ? Justifier votre réponse. Donner des solutions pour contrer ces deux attaques.

R2.
Efficacité : Le SYN flood est souvent plus efficace pour paralyser un serveur, car il cible spécifiquement les ressources de la couche transport (état des connexions), ce qui peut rapidement empêcher toute nouvelle connexion légitime.

Pour Contrer les Attaques TCP SYN Flood

Filtrage au Niveau du Pare-feu :

- Mise en place de règles de pare-feu pour détecter et bloquer les flux SYN excessifs.

Pour Contrer les Attaques ICMP Echo Request Flood

Filtrage ICMP :

- Configuration des pare-feu pour bloquer ou limiter le taux des requêtes ICMP.

Q3. Rappeler le principe de chiffrement avec des clés asymétriques. Comment peut on utiliser une telle approche pour authentifier un message ?

R3.

Définition :

- **Le chiffrement asymétrique, également connu sous le nom de cryptographie à clé publique, repose sur une paire de clés : une clé publique et une clé privée. Ces clés sont mathématiquement liées, mais il est pratiquement impossible de déduire l'une de l'autre.**

Voici les principes fondamentaux du chiffrement asymétrique :

Génération de Clés :

Une paire de clés est générée : une clé publique (diffusée largement) et une clé privée (gardée secrète).

Chiffrement :

Pour envoyer un message sécurisé, l'expéditeur (Alice) chiffre le message en utilisant la clé publique du destinataire (Bob).

Déchiffrement :

Le destinataire (Bob) utilise sa clé privée pour déchiffrer le message.

Authentifier un message :

- **L'authentification d'un message avec une approche asymétrique peut se faire par le biais des signatures numériques. Voici comment cela fonctionne :**

Création de la Signature :

- **L'expéditeur (Alice) crée une empreinte (ou hash) du message à l'aide d'une fonction de hachage.**
- **Alice chiffre cette empreinte avec sa clé privée pour créer une signature numérique.**

Envoi du Message :

- **Alice envoie le message et la signature numérique au destinataire (Bob).**

Vérification de la Signature :

- **Bob reçoit le message et la signature.**
- **Bob déchiffre la signature avec la clé publique d'Alice pour obtenir l'empreinte hachée originale.**
- **Bob applique la même fonction de hachage au message reçu pour générer une nouvelle empreinte.**
- **Bob compare l'empreinte déchiffrée à celle qu'il a calculée. Si elles correspondent, cela prouve que le message n'a pas été altéré et qu'il provient bien d'Alice.**

Q4. **Rappeler le principe de Kerckhoffs pour le chiffrement de données.**
R4.

Principe de Kerckhoffs: (*Maxime de Shanon*) : L'ennemi connaît l'algorithme utilisé, donc le secret repose sur le secret de clé et non sur le secret de l'algorithme.

Q5. **Définitions.**
R5. **Définitions des termes suivants :**

- **Usurpation d'adresse: est une technique utilisée pour falsifier l'identité d'un dispositif ou d'un utilisateur en utilisant de fausses adresses IP, MAC, ou e-mail dans les communications réseau. L'objectif principal de l'usurpation d'adresse est de tromper les systèmes de sécurité et les utilisateurs pour obtenir un accès non autorisé, intercepter des données, ou lancer des attaques malveillantes.**

- **IDS :**

  Définition

  Un équipement, logiciel ou matériel, qui automatise le processus d'analyse des événements d'un ordinateur/réseau pour y détecter des signes de problèmes de sécurité.

- **Non-répudiation : est un concept clé en sécurité de l'information, particulièrement important dans le contexte du chiffrement. La non-répudiation garantit qu'une partie ne peut pas nier ultérieurement avoir effectué une action, comme envoyer un message, signer un document, ou exécuter une transaction. Cela se fait généralement par des méthodes cryptographiques qui fournissent des preuves irréfutables de l'origine et de l'intégrité des données.**

- **Spoofing (Usurpation) : la prise d'identité d'autrui (utilisateur ou système) afin de gagner un accès illégitime à un système.**